
Decision of the National Commission sitting in a restricted formation on the outcome of investigation no. [...] conducted with "Company A"

1/46

Decision of the National Commission sitting in a restricted formation on the outcome of investigation no. [...] conducted with "Company A"
Deliberation no. 1FR/2025 of January 6, 2025

The National Commission for Data Protection sitting in a restricted formation, composed of Ms. Tine A. Larsen, President, and Messrs. Thierry Lallemand and Marc Lemmer, Commissioners;
Having regard to Regulation (EU) 2016/679 of the European Parliament and of the Council of April 27, 2016, on the protection of natural persons with regard to the processing of personal data and on the free movement of such data, and repealing Directive 95/46/EC;
Having regard to the law of August 1, 2018, organizing the National Commission for Data Protection and the general regime on data protection, in particular Article 41;
Having regard to the internal regulations of the National Commission for Data Protection adopted by decision no. 07AD/2024 dated February 23, 2024, in particular Article 10, paragraph 2;
Having regard to the regulation of the National Commission for Data Protection concerning the investigation procedure adopted by decision no. 08AD/2024 dated February 23, 2024, in particular Article 9;
Considering the following:

Decision of the National Commission sitting in a restricted formation on the outcome of investigation no. [...] conducted with "Company A"

2/46

Table of contents

I. Facts and procedure	3
II. In law	7
II.1. On the grounds for the decision	7
A. On the competence of the CNPD and the status of the controller	7
1. On the competence of the CNPD	7
2. On the status of the controller	7
B. On the breach related to the obligation to comply with response times to requests from data subjects (Article 12, paragraphs 3 and 4 of the GDPR)	8
1. On the principles	8
2. In this case	10
2.1. General considerations	11
2.1.1. Regarding the gap between the start of the investigation and the notification to the controller	11
2.1.2. Regarding the violation of Article 12, paragraphs 3 and 4 of the GDPR	13
2.1.3. Regarding the actions taken by the controller after the start of the investigation	16
2.1.4. Regarding the electronic mailbox of the Data Protection Officer	18
2.1.5. Regarding the context of COVID-19	23
2.2. Regarding the 47 complaints retained by the head of the investigation	24
2.3. Final conclusions	25
II.2. On the administrative fine and corrective measures	27
1. On the principles	27
2. In this case	30
2.1. Regarding the imposition of an administrative fine	30

2.1.1. Step 1: Identify the processing operations in this case	32
2.1.2. Step 2: Set the starting amount for the subsequent calculation of the fine	33
2.1.3. Step 3: Assess aggravating and mitigating circumstances	38
2.1.4. Step 4: Determine the applicable maximum legal amounts [...]	41
2.1.5. Step 5: Determine whether the final amount of the calculated fine is effective, proportionate, and deterrent	42
2.1.6. Appropriateness of the administrative fine	43
2.2. Regarding the implementation of corrective measures	44

Decision of the National Commission sitting in a restricted formation on the outcome of investigation no. [...] conducted with "Company A"

3/46

I. Facts and Procedure

1.

"Company A" is a [...] registered in the Trade and Companies Register of Luxembourg under number [...] and having its registered office at [...] (hereinafter referred to as the "controlled entity"). The controlled entity [...] [is a credit institution].¹ It is licensed and supervised by the Commission de surveillance du secteur financier (hereinafter referred to as the "CSSF") [...].²

2.

The controlled entity indicated that it employed an average of [...] employees for the year ending December 31, 2023, generated a net turnover of [...] for the year 2023, and achieved a net profit of [...] for the year 2023. [...].³

Furthermore, it declared that it is part of the group of Company B [...] (hereinafter referred to as "Company B") [...].

3.

Since the entry into force of Regulation (EU) 2016/679 of the European Parliament and of the Council of April 27, 2016, on the protection of natural persons with regard to the processing of personal data and on the free movement of such data, and repealing Directive 95/46/EC (hereinafter referred to as the "GDPR") on May 25, 2018, and until October 21, 2022, the National Commission for Data Protection (hereinafter referred to as the "CNPd" or the "National Commission") has received various complaints against the controlled entity raising the issue of the absence of responses from the controlled entity following requests to exercise the rights enshrined in Articles 15 to 22 of the GDPR.⁴ The complaints were filed by concerned individuals residing in different Member States of the European Union, including Luxembourg. Several complainants thus decided not to submit their complaint directly to the CNPD, but to the supervisory authority of their place of residence.⁵ However, the CNPD was identified through the European information exchange system as the competent "lead" supervisory authority to handle the complaints filed against the controlled entity.

1 Coordinated statutes of the controlled entity as of [...].

2 See the authorization [...] from the CSSF.

3 See email from the controlled entity dated June 20, 2024, and its annexes.

4 For the exact number of complaints considered in this decision, see section "II.1., Chapter B, Section 2.2. Regarding the 47 complaints retained by the lead investigator."

5 In accordance with Article 77.1 of the GDPR, which provides: "Without prejudice to any other administrative or judicial remedy, any data subject shall have the right to lodge a complaint with a supervisory authority, in particular in the Member State of his or her habitual residence, place of work or place of the alleged infringement, if he or she considers that the processing of personal data relating to him or her infringes this Regulation."

Decision of the National Commission sitting in a restricted formation on the outcome of investigation

no. [...] conducted with "Company A"

4/46

in accordance with the provisions of Article 56 of the GDPR to handle the relevant complaints filed against the controlled entity.

4.

During its deliberation session on October 21, 2022, the National Commission sitting in plenary formation decided to open an investigation into the controlled entity based on Article 38 of the law of August 1, 2018, on the organization of the National Commission for Data Protection and the general regime on data protection (hereinafter referred to as the "law of August 1, 2018") and to appoint Mr. Alain Herrmann as the lead investigator. This moment is referred to later in this decision as "the formal opening of the investigation."

5.

The aforementioned decision specified that the investigation conducted by the National Commission aimed to verify "based on the complaints open as of the date of signature of this decision the application and compliance with the provisions of the GDPR, the law of August 1, 2018, and legal texts providing specific provisions regarding the protection of personal data and more specifically the application and compliance with Article 12 paragraphs 3 and 4 of the GDPR."⁶

6.

The controlled entity was informed of the opening of the investigation against it by letter from the lead investigator dated July 18, 2023.⁷ This moment is referred to later in this decision as "the notification of the controlled entity regarding the opening of the investigation."

7.

The letter was accompanied by a document titled "INITIAL FINDINGS" outlining the initial findings made by the CNPD agents based on the documents collected in the context of 51 complaints submitted to this investigation (hereinafter referred to as the "initial findings"). The controlled entity was offered the opportunity to submit its written observations on the initial findings.

8.

At the request of the controlled entity, a meeting took place at the premises of the National Commission between the lead investigator and the controlled entity on September 12, 2023.

9.

The controlled entity responded to the initial findings by letter dated September 15, 2023, while providing additional documents and commenting on the various findings in a separate annex (hereinafter taken together as the "comments of the controlled entity").

6 Deliberation [...] of October 21, 2022, of the National Commission for Data Protection regarding the opening of an investigation into Company A.

7 DOCUMENT 6.

Decision of the National Commission sitting in a restricted formation on the outcome of investigation no. [...] conducted with "Company A"

5/46

controlled on the initial findings"), as well as on September 26, 2023, following the minutes of the aforementioned meeting sent by the investigator on September 18, 2023.

10. On December 8, 2023, the controlled party responded by email to the additional questions posed by the investigator on November 17, 2023.

11. At the end of his investigation, the investigator notified the controlled party on February 1, 2024, of a statement of objections (hereinafter: the "statement of objections") detailing the breaches he believed were constituted in this case concerning the requirements prescribed by Article 12,

paragraphs 3 and 4 of the GDPR. More specifically, the investigator was of the opinion that the controlled party failed to meet its obligations arising from Article 12, paragraphs 3 and 4 of the GDPR by violating the applicable response time for requests made to it by data subjects in the context of 48 complaints.

12. The investigator proposed to the National Commission sitting in a restricted formation (hereinafter: the "Restricted Formation") to adopt a corrective measure, as well as to impose an administrative fine of 502,190 euros on the controlled party.

13. The opportunity to submit written observations on the statement of objections was offered to the controlled party.

14. The latter communicated observations to the investigator by letter dated March 18, 2024 (hereinafter: the "written observations of the controlled party on the statement of objections").

15. In reply, the investigator notified the controlled party on April 2, 2024, of a second statement of objections modifying the statement of objections of February 1, 2024 (hereinafter: the "reply statement of objections"). The investigator maintained the breaches he believed were constituted in this case, as well as the corrective measure he proposed. However, based on the written observations of the controlled party, he considered that there was no need to maintain a violation of Article 12, paragraphs 3 and 4 of the GDPR concerning the complaint contained under finding no. 39 of the initial findings. Consequently, the number of complaints taken into account was reduced, as was the number of data subjects, from 48 to 47, and the amount of the proposed administrative fine was reduced to 493,560 euros.

16. The opportunity to submit written observations on the reply statement of objections was offered to the controlled party.

Decision of the National Commission sitting in a restricted formation on the outcome of investigation no. [...] conducted with "Company A"

6/46

17. By letter dated April 17, 2024, the controlled party duplicated and submitted its observations regarding the reply statement of objections (hereinafter: the "written observations of the controlled party on the reply statement of objections").

18. On April 23, 2024, the investigator transmitted the file to the Restricted Formation for a decision regarding the outcome of the investigation.

19. The president of the Restricted Formation informed the controlled party by letter dated April 26, 2024, that its case would be scheduled for the Restricted Formation session on June 6, 2024, and that it was offered the opportunity to be heard.

20. By email dated May 17, 2024, the controlled party confirmed its attendance at the said session.

21. During this session, the investigator [...] and the controlled party [...] presented their oral observations in support of their written observations and answered questions posed by the Restricted Formation. The Restricted Formation allowed the controlled party to submit additional information requested during the session within 2 weeks. The controlled party had the last word.

22. By email dated June 20, 2024, the controlled party provided the additional information requested by the Restricted Formation.

23. The decision of the Restricted Formation on the outcome of the investigation will be based on:

- the 47 complaints retained by the investigator in the reply statement of objections; and
- the legal and regulatory provisions taken into account by the investigator in his two statements of objections, and more specifically Article 12, paragraphs 3 and 4 of the GDPR concerning the deadlines to be respected by a data controller following a request to exercise a right by a data subject based on

Articles 15 to 22 of the GDPR (hereinafter: the "requests of data subjects"). However, as the analysis of the adequacy of a response provided to a data subject by the controlled party following such a request was not within the scope of the investigation in question, this issue will therefore not be addressed by the Restricted Formation in this decision.

24. The titles of the documents taken into account by the Restricted Formation are identical to those in the inventory of documents attached to the statement of objections in

Decision of the National Commission sitting in a restricted formation on the outcome of investigation no. [...] conducted with "Company A"

7/46

reply, except regarding the additional documents provided by the controlled entity that do not appear in the aforementioned inventory, such as those transmitted to the Restricted Formation following the hearing on June 6, 2024. Similarly, the Restricted Formation refers only to the communication of grievances in reply concerning the elements modified by the head of the investigation compared to the communication of grievances dated February 1, 2024, which appear therein as "follow-up to modifications."

II. In Law

II.1. On the grounds for the decision

A. On the competence of the CNPD and the status of the controlled entity

1. On the competence of the CNPD

25. Article 55, paragraph 1 of the GDPR states the following: "Each supervisory authority is competent to exercise the missions and powers conferred on it in accordance with this regulation on the territory of the Member State of which it is part."

26. Article 56, paragraph 1 of the GDPR, however, provides that: "Without prejudice to Article 55, the supervisory authority of the main establishment or the sole establishment of the controller or processor is competent to act as the lead supervisory authority concerning cross-border processing carried out by that controller or processor, in accordance with the procedure laid down in Article 60."

27. Since the controlled entity has its main establishment in the Grand Duchy of Luxembourg, the CNPD has been identified through the European information exchange system within the framework of European cooperation governed by Articles 60 to 62 of the GDPR as the competent "lead" supervisory authority in accordance with the provisions of Article 56 of the GDPR to handle the complaints in question and, therefore, to exercise its powers in this context based on Article 58 of the GDPR.

2. On the status of the controlled entity

28. In accordance with Article 4, point 7), of the GDPR, the controller is "the natural or legal person, public authority, agency, or other body which, alone or jointly with others, determines the purposes and means of the processing."

29. The head of the investigation noted in the communication of grievances (point 18) that the requests from the data subjects addressed to the controlled entity concerned the personal data processed by it in the context of its commercial activity and that the controlled entity was the entity that determined the purposes and means of the personal data processing carried out in this context.

30. The Restricted Formation notes that this assertion has not been contested by the controlled entity. It therefore considers that it should be regarded as the controller within the meaning of the GDPR for the personal data processing carried out in response to the requests of the data subjects.

B. On the breach related to the obligation to comply with response deadlines to requests from data subjects (Article 12, paragraphs 3 and 4 of the GDPR)

1. On the principles

31. Regarding the response deadlines to be respected by the controller following requests from data subjects, Article 12 of the GDPR provides the following:

"[...] 3. The controller shall provide the data subject with information on the measures taken in

response to a request made under Articles 15 to 22, without undue delay and in any event within one month of receiving the request. If necessary, this period may be extended by two months, taking into account the complexity and number of requests. The controller shall inform the data subject of any such extension and the reasons for the delay within one month of receiving the request. When the data subject submits the request in electronic form, the information shall be provided electronically where possible, unless the data subject requests otherwise.

4. If the controller does not take action on the request made by the data subject, it shall inform the data subject without delay and at the latest within one month of receiving the request of the reasons for its inaction and the possibility of lodging a complaint with a supervisory authority and seeking a judicial remedy. [...]"

Decision of the National Commission sitting in a restricted formation on the outcome of investigation no. [...] conducted with "Company A"

8/46

Decision of the National Commission sitting in a restricted formation on the outcome of investigation no. [...] conducted with "Company A"

9/46

32.

It follows from the above that a data controller must, in any case, respond to a request made by a data subject no later than within one month⁸ to:

–

provide information on the measures taken in response to the request in accordance with Article 12, paragraph 3, first sentence of the GDPR;

–

inform the data subject of the reasons for any possible extension of the response time by two months, taking into account the complexity and number of requests in accordance with Article 12, paragraph 3, second and third sentences of the GDPR;

–

inform the data subject that the request will not be followed up, as well as the reasons for such inaction and the possibility of lodging a complaint with a supervisory authority and seeking judicial remedy in accordance with Article 12, paragraph 4 of the GDPR.

33.

Article 12, paragraph 5 of the GDPR provides in this context that the data controller may refuse to comply with requests if they are manifestly unfounded or excessive, particularly due to their repetitive nature. In this case, it is the responsibility of the data controller to inform the data subject within one month, as mentioned above, demonstrating the manifestly unfounded or excessive nature of the request.

34.

Furthermore, Article 12, paragraph 6 of the GDPR⁹ provides that if "[...] the data controller has reasonable doubts as to the identity of the natural person making the request referred to in Articles 15 to 21, they may request that additional information necessary to confirm the identity of the data subject be provided."

Similarly, if the data controller processes a large amount of data concerning the data subject, they may ask the data subject to specify, before providing the information, which data or processing operations their request pertains to¹⁰.

⁸ See also Recital (59) of the GDPR: "[...] The data controller should be obliged to respond to requests from the data subject as soon as possible and at the latest within one month, and to provide reasons

for their response when they intend not to comply with such requests.”

9 See also Recital (64) of the GDPR: “The data controller should take all reasonable measures to verify the identity of a data subject making a request for access to data, particularly in the context of online services and identifiers. A data controller should not retain personal data solely for the purpose of being able to respond to potential requests.”

10 See also Recital (63) of the GDPR: “[...] When the data controller processes a large amount of data concerning the data subject, they should be able to ask the data subject to specify, before providing the information, which data or processing operations their request pertains to.”

Decision of the National Commission sitting in a restricted formation on the outcome of investigation no. [...] conducted with "Company A"

10/46

In both cases, the one-month response period is suspended until the data controller obtains the necessary information from the data subject. The suspension of the period means that the course of the period is temporarily halted without erasing the time already elapsed.

35.

Ultimately, it follows from the terms of Article 12, paragraphs 3 and 4 of the GDPR that the aforementioned one-month period starts from "the receipt of the request." This period must be calculated in accordance with Council Regulation No. 1182/71 of June 3, 1971, laying down rules applicable to periods, dates, and terms (hereinafter: "Regulation No. 1182/71"). Indeed, since the GDPR is a regulation of the European Parliament and of the Council of the European Union adopted under Article 16 of the Treaty on the Functioning of the European Union (hereinafter: "TFEU"), compliance with Regulation No. 1182/71 is mandatory.

36.

According to Article 3.2(c) of Regulation No. 1182/71, "a period expressed [...] in months [...] begins to run at the beginning of the first hour of the first day of the period and ends at the expiration of the last hour of the day which [...] in the last month [...], bears the same name or number as the starting day. If, in a period expressed in months [...] the determining day for its expiration is absent in the last month, the period ends at the expiration of the last hour of the last day of that month."

37.

Likewise, it should be noted that, according to Article 3.4 of Regulation No. 1182/71, "if the last day of a period expressed otherwise than in hours is a public holiday, a Sunday, or a Saturday, the period ends at the expiration of the last hour of the next working day."

Therefore, when a period is expressed in months, such as the periods provided for in Article 12, paragraphs 3 and 4 of the GDPR, this period begins to run on the day of receipt of the request and ends at midnight on the day which, in the following month, bears the same date as the day on which the request was made, or, if that last day is a public holiday, a Sunday, or a Saturday, the next working day.

2. In this case

38. The Restricted Formation notes that the investigation leader took into account in the initial findings 51 complaints "from which it appears that the complainants encountered difficulties in exercising their rights enshrined in Articles 15 to 22 of the GDPR, particularly regarding the absence of a response from the Controller within the time limits prescribed by Article 12, paragraphs 3 and 4, of the GDPR."

39. Based on the explanations and, where applicable, additional evidence submitted by the controller in its comments on the initial findings of September 15, 2023, as well as in its written observations on the statement of objections of March 18, 2024, the investigation leader ultimately retained a total of 47 complaints in its statement of objections in reply.

40. The Restricted Formation will therefore successively examine whether the response periods provided for in Article 12, paragraphs 3 and 4 of the GDPR were respected by the controller in the

context of the 47 complaints in question, which correspond to 47 of the 51 findings already retained in the initial findings. Nevertheless, to do so, it is necessary to first analyze certain contentious issues that are related either to general issues concerning the investigation conducted by the investigation leader (points 2.1.1 to 2.1.3), or to several of the complaints referred to in this decision (points 2.1.4 and 2.1.5).

2.1. General considerations

2.1.1. Regarding the gap between the start of the investigation and the notification to the controller

41. During its deliberation session on October 21, 2022, the National Commission sitting in plenary decided to open an investigation against the controller based on Article 38 of the law of August 1, 2018. The controller was informed of the opening of said investigation by letter from the investigation leader dated July 18, 2023, that is, approximately nine months later.

42. The controller expressed its concerns regarding this nine-month delay, as, even though it was not aware of the opening of said investigation against it, the CNPD, during this time, requested the controller to respond to certain complaints that were the subject of the aforementioned investigation.

43. During the Restricted Formation session on June 6, 2024, the investigation leader explained that this nine-month period corresponded to the time necessary for

12 Statement of objections, point 33.

13 See comments on the initial findings and written observations on the statement of objections, page 3.

Decision of the National Commission sitting in a restricted formation on the outcome of investigation no. [...] conducted with "Company A"

11/46

the investigation leader to gather the necessary information and conduct the preliminary analysis.

Decision of the National Commission sitting in a restricted formation on the outcome of investigation no. [...] conducted with "Company A"

12/46

to identify all claims falling within the scope of the investigation, as well as to gather all relevant factual elements.

44. The Restricted Formation wishes to emphasize that all claims considered by the head of the investigation were submitted by the concerned parties to the CNPD, or were transmitted to it by other relevant authorities, prior to the formal opening of the investigation on October 21, 2022.

45. Subsequently, it generally considers that it is not required for this preliminary phase of gathering relevant facts by the head of the investigation to be adversarial or for the subject to be immediately informed of the opening of the investigation, provided that the principle of adversarial proceedings is respected thereafter and that the subject can express its position on all facts taken into account by the head of the investigation.

It can only note that the subject had the opportunity at every stage of the investigation procedure to express its viewpoint and submit additional documents, notably by commenting on the initial findings retained by the head of the investigation, as well as on the communication of grievances, just as on the communication of grievances in reply.

Moreover, during the aforementioned session on June 6, 2024, the subject had the opportunity to reiterate its statements orally before the Restricted Formation.

Therefore, the Restricted Formation considers that no prejudice has been suffered by the subject and that its rights of defense have been fully respected.

46. Furthermore, it notes that during these nine months, that is to say, between the formal opening of the investigation and the notification to the subject about the opening of the investigation, the CNPD

indeed continued to communicate with the subject within the framework of the complaint procedure in the context of four of the claims taken into account in this decision.

47. First of all, it is of the opinion that the subject's position regarding the CNPD's correspondence in the context of the four claims, without being aware of the opening of the investigation, should not have differed from the one it would have taken if informed of said opening.

14 Article 8 point 1° of the regulation concerning the investigation procedure of the CNPD only provides that the subject "is informed by the head of the investigation by registered letter with acknowledgment of receipt of the decision to open the investigation," without specifying any deadline.

Decision of the National Commission sitting in a restricted formation on the outcome of investigation no. [...] conducted with "Company A"

13/46

48. With regard specifically to the claims contained in findings no. 17 and 20 of the initial findings, even though the CNPD continued to engage with the controller during the nine-month period in question regarding these two claims, all the documents considered by the head of the investigation are dated prior to the formal opening of the investigation.

49. Regarding the claims contained in findings no. 48 and 49 of the initial findings, the Restricted Formation notes that, following the transmission of the two claims by the supervisory authority [of country A] on August 26, 2022, the CNPD sent letters to the controller on December 27, 2022, and April 28, 2023, in the context of the investigation of said claims. The controller responded to these letters on January 11 and May 25, 2023. Such exchanges, in any case, fall within this nine-month period.

50. Even though these documents were taken into account by the head of the investigation, the Restricted Formation wishes to refer to Article 8 point 2° of the regulation concerning the investigation procedure of the CNPD, which provides that "[i]n the event that a claim is the basis for the opening of an investigation, the head of the investigation and the authorized agents take into account the retroactive elements of the investigation of the claim. The information, documents, and positions of the claimant and the controller thus become part of the investigation file." This is all the more relevant as, in both cases, the explanations provided by the controller in the letters exchanged between the formal opening of the investigation and the notification to the controller regarding said investigation were reiterated by the controller, following the notification by the head of the investigation of the opening of the investigation, and more specifically in its comments on the initial findings of September 15, 2023.

51. It therefore considers that the head of the investigation could take into account the aforementioned documents, provided that the controller could express its position regarding them in the context of the investigation. As mentioned above, this was indeed the case, as the controller had numerous opportunities to comment on all the various documents taken into account by the head of the investigation.

2.1.2. Regarding the violation of Article 12, paragraphs 3 and 4 of the GDPR

52. In the communication of grievances (point 348), the head of the investigation concluded that the controller "failed to meet its obligations arising from Article 12, paragraphs

15 For finding no. 17, the documents date from November 11, 2020, April 6, 2021, and April 27, 2021, and for finding no. 20 from May, June, August, and September 2020, from April 2021, as well as from March and April 2022.

16 Adopted by decision no. 08AD/2024 dated February 23, 2024, pursuant to Article 40 of the law of August 1, 2018, concerning the organization of the National Commission for Data Protection and the general regime on data protection. See also Article 8 of the procedure concerning complaints before the CNPD, which directly refers to said Article 8 point 2° of the regulation concerning the investigation procedure of the CNPD.

Decision of the National Commission sitting in a restricted formation on the outcome of investigation

no. [...] conducted with "Company A"

14/46

3 and 4 of the GDPR by having, on 48 occasions¹⁷, violated the applicable response time for requests made to it by data subjects in the context of the Complaints, as enumerated above."

53. In its written observations on the statement of objections¹⁸, the respondent argued that the information obligation provided for in Article 12, paragraph 4 of the GDPR would only apply if the data controller had intended not to act following a request from a data subject. However, in the majority of cases, the respondent intended to respond to the request, but for various reasons, it was unable to reply within the deadlines.

Similarly, according to the respondent, the deadline referred to in Article 12, paragraph 4 of the GDPR would not apply in cases where the data subjects are not properly identified. Thus, the respondent claims that it would have wanted to respond to the requests, but that additional information to identify the data subjects was necessary, in accordance with Article 12, paragraph 6 of the GDPR.

54. According to the respondent, requests for erasure based on Article 17 of the GDPR are the only requests for which the head of investigation could conclude that he had not fully responded to the requests of the data subjects. Nevertheless, in these cases, Article 17, paragraph 3 of the GDPR provides that the right to erasure does not apply in certain circumstances, notably when the legal retention period has not yet been reached. Unlike Article 15, paragraph 4 of the GDPR, under which the right of access may be limited but continues to exist, Article 17, paragraph 3 of the GDPR provides that the right to erasure does not exist at all in these cases.

Furthermore, in cases where the respondent would have relied on Article 17, paragraph 3 of the GDPR, it would not have intended to refuse to "respond to the request made by the data subject" within the deadline referred to in Article 12, paragraph 4 of the GDPR, but the respondent would have reacted by triggering the retention periods after which personal data may be deleted. Therefore, according to the respondent, it is disputable that Article 12, paragraph 4 of the GDPR is applicable to erasure requests if Article 17, paragraph 3 of the GDPR applies. Thus, in cases where the data subject has not exercised their right to erasure, the respondent believes that the National Commission should at least conclude that it has not violated Article 12, paragraph 4 of the GDPR.

¹⁷ Reduced to 47 in the statement of objections in reply.

¹⁸ See points 100 to 104.

Decision of the National Commission sitting in a restricted formation on the outcome of investigation no. [...] conducted with "Company A"

15/46

55. During the hearing of the Restricted Formation on June 6, 2024, the head of investigation stated that the same deadline, the same starting point for the deadline, and the same objective are provided for in Article 12, paragraphs 3 and 4 of the GDPR. He therefore focused on the scope of the investigation, which consists solely of verifying whether the respondent sent a response within the one-month deadline, without analyzing the substance of the responses. Similarly, for cases where there was no response at all, it was therefore not possible to say whether Article 12, paragraph 3 or Article 12, paragraph 4 of the GDPR were not respected. The head of investigation also emphasized that in any case, this analysis would not have impacted the corrective measures proposed to the Restricted Formation.

56. The Restricted Formation wishes to remind in this context that the present decision will be based on the 47 complaints contained in the statement of objections in reply, as well as on the legal and regulatory provisions taken into account by the head of investigation in his statement of objections, and more specifically Article 12, paragraphs 3 and 4 of the GDPR concerning the deadlines to be respected by a data controller following requests from data subjects.

57. Therefore, just as the head of investigation did, the Restricted Formation will only analyze in this decision whether at the time of the introduction of the complaints, or even at the time of the transmission of the complaints to the CNPD by another supervisory authority, the complainants received a response within the deadlines provided for in Article 12, paragraphs 3 and 4 of the GDPR. On the other hand, to the extent that the analysis of the adequacy of a response provided to a data subject by the respondent following such a request does not fall within the scope of the investigation in question, this issue will therefore not be addressed by the Restricted Formation in this decision.

58. In cases where the Restricted Formation finds that the respondent did not respond within the deadlines provided for in Article 12, paragraphs 3 and 4 of the GDPR, it will not analyze the content of a response that may have been given subsequently by the respondent to the data subject. It will therefore not take a position on whether such a response would aim to respond to a request in accordance with Article 12, paragraph 3 of the GDPR, or whether it would contain reasons justifying a possible inaction of the respondent as provided for by Article 12, paragraph 4 of the GDPR.

59. In other words, regardless of the rights exercised by the complainants under Articles 15 to 22 of the GDPR, the Restricted Formation will limit itself to verifying

Decision of the National Commission sitting in a restricted formation on the outcome of investigation no. [...] conducted with "Company A"

16/46

if the complainants received a response within the time limits set out in Article 12, paragraphs 3 and 4 of the GDPR.

60. It will also take into account the assertion of the controller that Article 12, paragraph 4 of the GDPR does not apply in cases where the data subject has not properly identified themselves. Indeed, in such cases, the controller intended to respond to this request, but in accordance with Article 12, paragraph 6 of the GDPR, additional information to identify the data subject was necessary. In such cases, it will only analyze whether the complainant received a response within the time limits set out in Article 12, paragraphs 3 and 4 of the GDPR, or whether a clear identity verification was formulated by the controller within those time limits, potentially resulting in a suspension of those deadlines.

2.1.3. Regarding the actions taken by the controller after the start of the investigation

61. In its comments on the initial findings, the controller indicated that it had proactively contacted the CNPD during the period covered by the investigation in question to discuss the improvements planned in their privacy program [...], and stated that it had closely cooperated with the CNPD to implement these changes. It further indicated that its practices regarding the processing of requests from data subjects were already effective when the GDPR came into force, but that they had been significantly improved over the past five years as part of their privacy program [...].

For example, [...] different types of training have been implemented for both new employees and existing employees, as well as procedures, policies, and response templates to better frame the processing of requests from data subjects by customer service agents. Additionally, the controller specified that it had received during the period under investigation a total of [...] requests from data subjects and that the 51 complaints in question would represent only a very small fraction of this amount [...].

62. Similarly, the controller explained that it had modified its identity verification methods [...] [and the channels for submitting requests from data subjects].

63. In its written observations on the communication of grievances, the controller expressed its surprise at the reiteration of violations of Article 12, paragraphs 3 and 4 of the GDPR by the head of the investigation, despite its additional explanations and significant efforts made to comply with the GDPR. It also believed that there would not have been a violation of Article 12, paragraphs 3 and 4 of the GDPR when the response time was related to a force majeure event (the COVID-19 crisis) or to

the fault of the data subjects, particularly when they did not provide the necessary information for identity verification. According to the controller, the principles of civil law under which a person would be excused for committing an infringement, if it was not caused by their own fault but by external factors beyond the controller's control, should also apply to the obligations of the GDPR¹⁹.

64. However, the Restricted Formation believes that any non-compliance with the GDPR is objectively constitutive of a violation of the GDPR. Applied to the cases at hand, this means that the absence of a response from the controller within the time limits set out in Article 12, paragraphs 3 and 4 of the GDPR, to a request made by a data subject, according to the applicable formalities, constitutes a violation of the GDPR.

65. The facts and elements taken into account in this decision in the context of the 47 complaints analyzed below are therefore those existing on the day the controller was informed of the opening of the investigation on July 18, 2023, as subsequently commented on by the controller. Any modifications made by the controller during the investigation and before the decision of the Restricted Formation, even if they allow for full or partial compliance to be established, do not retroactively annul a confirmed breach.

66. This position was confirmed in a recent judgment of the administrative court on May 14, 2024, in the context of an appeal filed by a public limited company against a decision of the CNPD. More concretely, the court held that "the defendant's argument that the CNPD failed to take into account, in its decision of May 31, 2021, the measures taken during the investigation and prior to the issuance of said decision is to be rejected for lack of basis. It is indeed explicitly stated in the aforementioned decision, a position further confirmed by the CNPD in its response and reply submissions, that it held that to establish the breaches of the applicant against the GDPR, it only considered the facts as they existed on the day of

19 See written observations on the communication of grievances, page 1 and point 66.

Decision of the National Commission sitting in a restricted formation on the outcome of investigation no. [...] conducted with "Company A"

17/46

Decision of the National Commission sitting in a restricted formation on the outcome of investigation no. [...] conducted with "Company A"

18/46

the opening of the investigation and that any modifications made by the applicant during the investigation and before the issuance of the contested decision do not eliminate a proven infringement, the court adopting, in this case, the same approach regarding the alleged infringements and regarding the principle of the fine to be retained, if applicable, against the applicant.

67. As mentioned in this judgment, the steps taken by the controlled entity to comply with the GDPR during the investigation procedure or to remedy the infringements identified by the investigator in the communication of grievances, as well as, if applicable, mitigating circumstances external to the will of the controlled entity, such as the number of requests received from the data subjects, may be taken into account by the Restricted Formation, provided they are relevant, in the context of any corrective measures to be imposed and/or any administrative fine to be imposed.

68. It refers in this context to Chapter II.2., Section 2.2. of this decision for the relevant explanations.

2.1.4. Regarding the electronic mailbox of the Data Protection Officer

69. It appears from part of the complaints contained in the initial findings that the controlled entity did not respond within the time limits set out in Article 12, paragraphs 3 and 4 of the GDPR to requests from the data subjects, which were sent to the electronic mailbox of the Data Protection Officer

(hereinafter: the "DPO") of the controlled entity, that is to the address [DPO's electronic address].

70. In its comments on the initial findings, the controlled entity explained in the context of the relevant complaints that at the time the requests were sent to the electronic mailbox [of the DPO], its operation was affected by a technical error. This malfunction had been identified by the controlled entity and communicated to the CNPD during a meeting on October 6, 2020. This problem had, moreover, been resolved in the meantime.

More specifically, the controlled entity specifies, in its aforementioned comments, that in view of the number of unwanted emails ("spam") received in the electronic mailbox in question, it would no longer have been technically possible to filter the genuine requests from the data subjects. The controlled entity further specifies that it has developed measures to prevent this problem in the electronic mailbox [of the DPO], notably by deploying [new channels for submitting requests from data subjects] since December 2020 [...].

71. In the communication of grievances (point 343), the investigator took a general position on the "malfunction of the electronic mailbox [of the DPO]" by stating "based on the Complaints, that this malfunction appeared as early as December 2019 and persisted until December 2020. The first relevant cases were subject to a letter from the CNPD to the Controlled Entity, as part of the Complaint procedures, as early as August and September 2020. The Controlled Entity then informed the CNPD, for the first time in October 2020, of said malfunction, so that, contrary to the repeated assertions of the Controlled Entity, it did not 'proactively' inform the CNPD.

The investigator also notes that the email address [of the DPO] appeared, from [...] April 2019 until [...] December 2020, on the privacy policy of the Controlled Entity as the contact email address (DOCUMENTS 8 to 10).".

72. In its written observations on the communication of grievances, the controlled entity specified that the electronic mailbox of the DPO was not the usual or designated contact channel for data subjects exercising a right. Referring to DOCUMENTS 8 and 9, it added that in its privacy policy at the time there was a contact form allowing data subjects to send their requests to the appropriate services of Company A and that the email address of the DPO had only been a secondary contact point and not the primary means of communication for data subjects.

For this reason, the controlled entity was of the opinion that, even if a technical error had prevented requests from data subjects from reaching it, alternative means would have been available to those individuals, notably the contact form. The purpose of the electronic mailbox of the DPO would have been to receive questions related to privacy, but, as said address would have been publicly available, there would have been abuses in sending unwanted or non-privacy-related emails.

Decision of the National Commission sitting in a restricted formation on the outcome of investigation no. [...] conducted with "Company A"

19/46

Decision of the National Commission sitting in a restricted formation on the outcome of investigation no. [...] conducted with "Company A"

20/46

Finally, the controlled party explains that, although not all communications sent to the DPO's electronic mailbox had been visible and delivered due to the aforementioned error, he had received and responded to requests sent to this mailbox that had not been unavailable, but functional. This would explain why the problem had not been directly identified, as Company A had always received requests on said mailbox, but only a limited number of requests had not been received. During tests conducted in July and August 2020, the controlled party indeed found that certain emails were not visible in the DPO's electronic mailbox and responses to these emails had been sent at that time.

73.

As a preliminary matter, the Restricted Formation first notes that in its written observations on the communication of grievances, the controlled party criticized that the head of the investigation had not mentioned the issue related to the DPO's electronic mailbox in his letters of August and September 2020 and that Company A had proactively informed the CNPD during a meeting on October 6, 2020. Similarly, the controlled party believed that the fact that this issue had not been raised in an email sent to Company A on October 23, 2020, would be evidence that this aspect had not been a concern for the CNPD.

74.

However, it notes that in the letter sent by the CNPD to the controlled party dated August 6, 2020, in the context of the complaint contained in finding no. 6 of the initial findings (see EXHIBIT [...]), the CNPD mentioned that no response had been sent to the emails sent by the complainant to the DPO's email address, while requesting confirmation (or not) of the receipt of said requests dated December 4 and 13, 2019, and, if applicable, justifications for the absence of response within the required timeframes. Likewise, in case the initial requests sent to the DPO's email address could not be traced in Company A's systems, the CNPD requested in said letter clarifications on the measures taken to prevent similar incidents in the future, such as filtering emails from requests of data subjects as spam.

75.

Furthermore, even if the CNPD's email of October 23, 2020, highlighted by the controlled party did not specifically mention that the issue related to the controlled party's DPO electronic mailbox had been discussed during the meeting between the CNPD and the controlled party on October 6, 2020, the Restricted Formation notes, on the one hand, that this point was not the main subject of this meeting, and on the other hand, it was impossible for the CNPD to understand the scope of the issue at that time, as it had only contacted the controlled party on this matter in the context of two complaints.

76.

Based on the above, the Restricted Formation concludes that the issue of the lack of responses to certain requests sent by data subjects to the DPO's email address was indeed raised by the CNPD in its letter of August 6, 2020, and that the problem was not proactively reported by the controlled party to the CNPD during the aforementioned meeting on October 6, 2020.

77.

In any case, regarding the controlled party's argument that the DPO's electronic mailbox would have only been a secondary point of contact and that there would have been a contact form allowing data subjects to send their requests to the appropriate services of Company A, the Restricted Formation takes into account the privacy policies of the controlled party as they were in effect from [...] April 2019 until at least [...] December 2020 (EXHIBIT 10 being the privacy policy that came into effect on [...] December 2020 on Company A's website, but the Restricted Formation does not have evidence on the validity period of this policy).

It notes that in the section titled "[Contact]," there was a link to a contact form in case of "questions about your account [...]", but this form referred to the first part of this section which referred to general questions and not specifically to requests for the exercise of rights. However, at the end of this same section, the possibility of contacting the controlled party's DPO via the email address [of the DPO] or by postal mail was mentioned.

78.

Contrary to the claims of the controlled party, it follows from its privacy policies that the contact form was intended for users experiencing problems with their account [...], while requests from data subjects could be addressed to the DPO, who should not be considered a secondary point of contact in this matter. The GDPR expressly provides in Article 38, paragraph 4 that "data subjects may contact the data protection officer regarding all questions relating to the processing of their

24 Complaints outlined in findings no. 6 and 9 of the initial findings.

Decision of the National Commission sitting in a restricted formation on the outcome of investigation no. [...] conducted with "Company A"

21/46

Decision of the National Commission sitting in a restricted formation on the outcome of investigation no. [...] conducted with "Company A"

22/46

personal data and the exercise of the rights conferred upon them by this regulation."

79. Furthermore, according to the guidelines regarding DPOs from the European Data Protection Board (hereinafter "EDPB"), the requirement to publish the contact details of the DPO in accordance with Article 37, paragraph 7 of the GDPR aims precisely to ensure that data subjects "can easily and directly contact the DPO without having to go through another department of the organization."²⁶

80. The Restricted Formation therefore considers that during this period, namely between [...] April 2019 and at least [...] December 2020, there was no obligation for data subjects to send their requests solely via the contact form. Furthermore, the fact that other means of communication, in addition to the DPO's electronic mailbox, were available, such as the aforementioned form, did not exempt the controller from its obligation to process requests sent to the DPO's electronic mailbox within the applicable deadlines.

81. It takes into account that during the problematic period, certain emails sent to [the DPO's email address] were processed by the controller. For this reason, the Restricted Formation does not consider that there was a total failure of the DPO's electronic mailbox, but, as also mentioned by the head of the investigation in the statement of objections, that it was affected by a malfunction.

82. Moreover, the Restricted Formation has no evidence to support the controller's claims that only a limited number of requests sent to [the DPO's email address] were not received by the controller or that said electronic mailbox was functional, for the most part, during the disputed period.

83. Based on the above, it concludes that between [...] April 2019 and at least [...] December 2020, the DPO's electronic mailbox of the controller ([...]) should be considered an official channel for receiving requests from data subjects, even if alternatives existed. This mailbox should therefore have been functional, and the requests sent by data subjects should have been processed by the controller within the deadlines provided for in Article 12, paragraphs 3 and 4 of the GDPR.

84. Finally, it considers that the starting point for the deadlines provided for in Article 12, paragraphs 3 and 4 of the GDPR, to be taken into account in the relevant complaints, is each time the date of sending the email addressed to the DPO's electronic mailbox, even if the controller did not immediately receive or see it due to the technical issue mentioned earlier. This view has been confirmed by the EDPB in its guidelines on the right of access (hereinafter "guidelines 01/2022") stating that "[t]he deadline starts to run when the data controller has received a request under Article 15, that is, when the request reaches the data controller through one of its official channels. It is not necessary for the data controller to have actual knowledge of the request."²⁷

2.1.5. Regarding the context of COVID-19

85. In three of the complaints contained in the initial findings,²⁸ the controller explained that the failure to comply with the response deadlines provided for in Article 12, paragraphs 3 and 4 of the GDPR is related to the context of COVID-19, as the mailroom was not fully operational, which caused delays in processing mail.

86. Nevertheless, the head of the investigation considered that at the time of the events, the COVID-19

crisis had already been ongoing for more than eight months and that the controller had thus had sufficient time to adapt its mail management. Such adaptations could be expected from a credit institution registered with the CSSF and therefore required to have a business continuity plan. The head of the investigation was therefore of the opinion that this circumstance did not exempt the data controller from its obligations towards data subjects.²⁹

87. In its observations made against the statement of objections³⁰, the controller specified that the delay in processing requests was related solely to the

27 EDPB guidelines 01/ on the rights of data subjects — Right of access, Version 2.0 adopted on March 28, 2023, point 159.

28 See the complaints set out in findings nos. 21, 22, and 31 of the initial findings. In finding no. 25, COVID-19 was also mentioned, but the Restricted Formation did not retain any complaints regarding it (see the explanations related to complaint no. 25 in the section concerning the initial findings).

29 See statement of objections, points 161, 168, 189, 229.

30 See points 90 to 96.

Decision of the National Commission sitting in a restricted formation on the outcome of investigation no. [...] conducted with "Company A"

23/46

processing of requests.

Decision of the National Commission sitting in a restricted formation on the outcome of investigation no. [...] conducted with "Company A"

24/46

exceptional circumstances of the COVID-19 crisis, which would have interrupted the normal working conditions of its employees. This pandemic would have been an unpredictable and external event making it impossible to fully comply with the deadlines set out in Article 12 of the GDPR.

Furthermore, the controller argued that the impact of the pandemic should have been taken into account by the head of the investigation, as during this period the controller had to close its offices, which reduced the availability of its employees to handle requests [...].

Similarly, the controller confirmed, in its aforementioned observations, that as a credit institution registered with the CSSF, it had a business continuity plan which allowed it to respond in the majority of cases within the stipulated deadlines, but that the challenges posed by the pandemic had inevitably created delays that could not be attributed to it.

In light of these reasons and in this context, the controller believes that there has been no violation of Article 12, paragraphs 3 and 4 of the GDPR.

88.

While the Restricted Formation can take into account the aforementioned explanations from the controller and can only agree that the impact of the COVID-19 pandemic was considerable, it must nevertheless consider that the data controller should have always complied with the deadlines set out in Article 12, paragraphs 3 and 4 of the GDPR, even during a pandemic. The aforementioned considerations therefore have no impact on the objective finding of a violation of the GDPR in the event of non-compliance with the aforementioned deadlines. Nevertheless, as mentioned in point 68 of this decision, any mitigating circumstances external to the will of the controller may be taken into account by the Restricted Formation, provided they are relevant, in the context of any corrective measures to be imposed and/or any administrative fine to be imposed.

2.2. Regarding the 47 complaints retained by the head of the investigation

89.

The Restricted Formation is now proceeding to analyze the 47 complaints retained by the head of the investigation in its statement of objections in reply and initially contained in the initial findings. It wishes to clarify that it has taken note of all comments on the various complaints contained in the multiple exchanges between the head of the investigation and the controller, notably in the initial findings of the head of the investigation and in the comments of the controller on said findings, in the statement of objections and in the reply, as well as in the written observations related thereto from the controller. Nevertheless, the Restricted Formation will focus in this context solely on the analysis of the facts that are necessary to examine whether the deadlines set out in Articles 12, paragraphs 3 and 4 of the GDPR have been respected by the controller.

On the other hand, the explanations regarding the steps taken by the controller to comply with the GDPR during the investigation procedure or to remedy the shortcomings identified by the head of the investigation in the statement of objections may be taken into account by the Restricted Formation, provided they are relevant, in the context of any corrective measures to be imposed and/or any administrative fine to be imposed.

[...]

2.3. Final conclusions

90.

Based on the preceding considerations, the Restricted Formation has primarily identified three causes that led to a late response or a lack of response by the controller to the requests of the data subjects:

- various human errors³¹;
- the technical error affecting the electronic mailbox of the controller's DPO ([...])³²; and
- identity verification requests that were not clearly formulated or sent via inaccessible channels³³.

91.

Regarding human errors, it should be noted that in the context of certain complaints, the customer service of the controller failed to differentiate a request from a data subject from a parallel request related to another subject, such as a dispute concerning the complainant's account, a question about account closure, or a financial transaction³⁴, and consequently, no response was provided to the complainants within the required deadlines regarding their requests in accordance with Articles 15 to 22 of the GDPR.

31 See in particular the complaints set out in findings no. 2, 3, 7, 11, 13, 16, 24, 26, 27, 41, 42, 43, 48, 50, and 51.

32 See in particular the complaints set out in findings no. 6, 9, 10, 15, 17, 19, 36, 37, 44, and 45. See also the explanations contained in section "2.1.4. Regarding the electronic mailbox of the data protection officer of the controller."

33 See in particular the complaints set out in findings no. 20, 23, 28, 29, 30, 35, 47, and 49.

34 See in particular the complaints set out in findings no. 3, 7, 11, 16, 26, and 41.

Decision of the National Commission sitting in a restricted formation on the outcome of investigation no. [...] conducted with "Company A"

25/46

Decision of the National Commission sitting in a restricted formation on the outcome of investigation no. [...] conducted with "Company A"

26/46

Similarly, in some cases, the request was not properly transmitted internally to the competent department of the controller responsible for handling requests from the data subjects³⁵ or the request was processed internally, but due to a human error on the part of the agent responsible for responding to the request, the response was never sent to the complainant³⁶. In one case, a response was sent within a month, but to an incorrect email address, as a "dot" was missing between the first name and the last name of the complainant, resulting in the complainant being unaware of the follow-up to their request³⁷.

92.

Furthermore, in other complaints, a request for identity verification was sent via a channel inaccessible to the data subject [...], despite the fact that this inaccessibility had been repeatedly brought to the attention of the controller, so that this request did not suspend the response deadlines, which were therefore not respected³⁸. In this same context, and without ruling on whether such an identity verification would have been legitimate, the Restricted Formation found in the context of certain complaints that no clear request for identity verification had been made by the controller to the complainants, and therefore, the response deadlines were not suspended³⁹.

93.

Moreover, in the context of two complaints, the controller indicated that they could not find a postal letter, but which was received by them according to the acknowledgment of receipt⁴⁰.

94.

Regarding the COVID-19 pandemic, the controller explained that during this time the mailroom was not fully operational, which caused processing delays in two cases, and the response to an email could not be made within the deadlines for the same reason⁴¹.

95.

Finally, concerning the consideration of the steps taken by the controller to improve the management of requests from data subjects and thus reduce the risk of a response outside the prescribed deadlines in the future, the Restricted Formation refers to section "2.1.3. Regarding the steps taken by the controller after the start of the investigation"⁴².

96.

In conclusion, while it can take these elements into account, provided they are relevant, in the context of any corrective measures to be imposed and/or the setting of any potential administrative fine to be imposed, the Restricted Formation can only note that the controller violated Article 12, paragraphs 3 and 4 of the GDPR by failing to respond within the required deadlines to requests made by data subjects in the context of 46 of the 47 complaints mentioned in this decision.

II.2. On the administrative fine and corrective measures

1. On the principles

97.

In accordance with Article 12 of the law of August 1, 2018, the National Commission has the powers provided for in Article 58, paragraph 2 of the GDPR:

- "a) warn a data controller or a processor that the intended processing operations are likely to violate the provisions of this regulation;
- b) reprimand a data controller or a processor when the processing operations have resulted in a violation of the provisions of this regulation;
- c) order the data controller or processor to comply with requests made by the data subject in order to exercise their rights under this regulation;
- d) order the data controller or processor to bring the processing operations into compliance with the provisions of this regulation, where appropriate, specifically and within a determined period;
- e) order the data controller to communicate to the data subject a personal data breach;
- f) impose a temporary or definitive limitation, including a prohibition, on processing;
- g) order the rectification or erasure of personal data or the restriction of processing in accordance with

Articles 16, 17, and 18 and the notification of these measures to the

42 Regarding the modifications made concerning the electronic mailbox of the DPO, the Restricted Formation refers to point "2.1.4. Regarding the electronic mailbox of the data protection officer of the controller" of this decision.

Decision of the National Commission sitting in a restricted formation on the outcome of investigation no. [...] conducted with "Company A"

27/46

Decision of the National Commission sitting in a restricted formation on the outcome of investigation no. [...] conducted with "Company A"

28/46

recipients to whom personal data have been disclosed pursuant to Article 17, paragraph 2, and Article 19;

h) withdraw a certification or order the certification body to withdraw a certification issued pursuant to Articles 42 and 43, or order the certification body not to issue a certification if the applicable certification requirements are not or are no longer met;

i) impose an administrative fine pursuant to Article 83, in addition to or instead of the measures referred to in this paragraph, depending on the specific characteristics of each case;

j) order the suspension of data flows addressed to a recipient located in a third country or to an international organization.

98.

In accordance with Article 48 of the law of August 1, 2018, the CNPD may impose administrative fines as provided for in Article 83 of the GDPR, except against the State or municipalities.

99.

Article 83, paragraph 1 of the GDPR provides that each supervisory authority ensures that the administrative fines imposed are, in each case, effective, proportionate, and dissuasive.

100.

Article 83, paragraph 2 specifies the criteria that must be taken into account to decide whether to impose an administrative fine and to determine the amount of that fine:

“a) the nature, gravity, and duration of the violation, taking into account the nature, scope, or purpose of the processing concerned, as well as the number of affected individuals and the level of damage they have suffered;

b) whether the violation was committed intentionally or negligently;

c) any measures taken by the data controller or the processor to mitigate the damage suffered by the affected individuals;

d) the degree of responsibility of the data controller or the processor, taking into account the technical and organizational measures they have implemented pursuant to Articles 25 and 32;

e) any relevant previous violations committed by the data controller or the processor;

Decision of the National Commission sitting in a restricted formation on the outcome of investigation no. [...] conducted with "Company A"

29/46

f) the degree of cooperation established with the supervisory authority in order to remedy the violation and mitigate any potential negative effects;

g) the categories of personal data concerned by the violation;

h) how the supervisory authority became aware of the violation, including whether, and to what extent, the data controller or the processor notified the violation;

- i) when measures referred to in Article 58, paragraph 2, have previously been ordered against the data controller or the processor for the same subject matter, compliance with those measures;
 - j) the application of approved codes of conduct pursuant to Article 40 or approved certification mechanisms pursuant to Article 42; and
 - k) any other aggravating or mitigating circumstances applicable to the circumstances of the case, such as the financial benefits gained or the losses avoided, directly or indirectly, as a result of the violation.”
- 101.

The imposition of administrative fines has been clarified by the Article 29 Working Party in its “Guidelines on the application and setting of administrative fines for the purposes of Regulation (EU) 2016/679” (WP 253) adopted on October 3, 2017 (hereinafter: the “Guidelines on the application and setting of fines”). These guidelines have been approved by the EDPS.

The Restricted Formation emphasizes that the Guidelines on the application and setting of fines have been supplemented by the “Guidelines 04/2022 on the calculation of administrative fines under the GDPR” from the EDPS, the version 2.1 of which was adopted on May 24, 2023 (hereinafter: the “Guidelines on the calculation of fines”). These guidelines specify a method that supervisory authorities may apply to calculate administrative fines in light of the circumstances of each specific case. This method consists of five steps. However, supervisory authorities are not required to apply all the steps if they are not relevant in a given case, nor to provide reasoning regarding aspects of the guidelines that are not applicable.

43 EDPS, Decision “Endorsement 1/2018” of May 25, 2018.

44 Guidelines on the calculation of fines, page 3; for an overview of the method, see point 17 of the guidelines.

45 Guidelines on the calculation of fines, point 6.

Decision of the National Commission sitting in a restricted formation on the outcome of investigation no. [...] conducted with "Company A"

30/46

102. The Restricted Formation wishes to clarify that the facts and elements taken into account in the context of this decision are those existing on the day the controlled entity was informed of the opening of the investigation on July 18, 2023, as subsequently commented on by the controlled entity. Any modifications made by the controlled entity during the investigation and before the decision of the Restricted Formation, even if they fully or partially establish compliance, do not retroactively annul an established infringement (see also point 65 and following of this decision).

103. Nevertheless, the steps taken by the controlled entity to comply with the GDPR during the investigation procedure, or to remedy the infringements identified by the head of the investigation in the statement of objections, may be taken into account by the Restricted Formation in the context of any corrective measures to be imposed and/or any potential administrative fine to be imposed.

2. In this case

2.1. Regarding the imposition of an administrative fine

104. In the statement of objections, the head of the investigation proposed to the Restricted Formation to impose an administrative fine of 502,190 euros against the controlled entity. In the reply statement of objections, the violation of Article 12, paragraphs 3 and 4 of the GDPR was not maintained concerning the complaint contained in finding no. 39 of the initial findings. The number of complaints taken into account, as well as the number of affected individuals, has therefore decreased from 48 to 47. For this reason, the head of the investigation reduced the amount of the proposed administrative fine to 493,560 euros (see also point 15 of this decision).

105. The controlled entity, in its written observations, argued that, based on the facts of the case, it should not be sanctioned and that, in particular, no fine should be imposed on it. In support of its arguments, it first contested that the violation of the GDPR was committed negligently within the

meaning of Article 83, paragraph 2, point b) of the GDPR. Furthermore, it claimed that the other criteria of Article 83, paragraph 2 of the GDPR would not justify any fine.

46 Statement of objections, point 379.

47 Reply statement of objections, point 374.

48 See in particular the written observations of the controlled entity on the reply statement of objections, point 13, and the written observations of the controlled entity on the statement of objections, point 105 and following.

49 See written observations of the controlled entity on the statement of objections, point 110 and following.

Decision of the National Commission sitting in a restricted formation on the outcome of investigation no. [...] conducted with "Company A"

31/46

plus the imposition of an administrative fine⁵⁰ and that the proposed fine would not be effective, proportionate, and deterrent within the meaning of Article 83, paragraph 1 of the GDPR⁵¹. Furthermore, regarding the turnover of the company considered for the calculation of the proposed fine, the subject has contested being part of an "economic unit" with Company B. Moreover, he argued that if the Restricted Formation reached the opposite conclusion, it should only take into account the part of the turnover corresponding to the processing that is contested. That is to say, the turnover of the subject, in his capacity as the data controller within the meaning of the GDPR, for the processing of personal data related to the requests of the data subjects⁵². During the session of the Restricted Formation on June 6, 2024, the subject again requested that an administrative fine not be imposed on him. In particular, he insisted that his behavior could not be characterized as negligent, as he would have acted as a diligent data controller. Furthermore, he claimed that the imposition of a fine would be neither necessary nor proportionate, while referring to the conclusions of the Advocate General at the Court of Justice of the European Union (hereinafter: the "CJEU") in the "Land Hessen" case⁵³. In addition, he added that the Guidelines on the calculation of fines did not yet exist at the time of the facts in question and would therefore not be applicable in this case.

106. Regarding the Guidelines on the calculation of fines, the Restricted Formation notes that the EDPB adopted them on May 24, 2023 (see point [101.] of this decision), that is to say, after the formal opening of the investigation on October 21, 2022. Nevertheless, it considers that there is no reason to disregard these guidelines, as they reflect the common understanding of the EDPB regarding the provisions of Article 83 of the GDPR. Furthermore, the Guidelines on the calculation of fines are intended for supervisory authorities and not for data controllers or processors. Indeed, supervisory authorities use them to ensure consistent application of the GDPR⁵⁴.

107. For the remainder, the Restricted Formation wishes to clarify that it has taken note of all comments on the imposition of an administrative fine, contained in the

50 See written observations of the subject on the communication of grievances, point 122. and following.

51 See written observations of the subject on the communication of grievances, point 178. and following. The Restricted Formation notes that the subject in the aforementioned point 178 referred to "Article 83(2) GDPR." However, it considers this to be a typographical error.

52 See written observations of the subject on the communication of grievances, point 188. and following.

53 CJEU, Conclusions of Advocate General Mr. Priit Pikamäe of April 11, 2024, Land Hessen (Obligation of the data protection authority to act), C-768/21, ECLI:EU:C:2024:291).

54 Guidelines on the calculation of fines, points 4. and 14.

Decision of the National Commission sitting in a restricted formation on the outcome of investigation

multiple exchanges between the head of the investigation and the controlled party, particularly in the communication of the grievances and the response, as well as in the written observations related to them from the controlled party. Nevertheless, it will focus solely on the analysis of the facts that are necessary to decide whether to impose an administrative fine and to determine, if applicable, the amount of the administrative fine in light of the criteria set forth in Article 83 of the GDPR. The Restricted Formation will apply in this context the five-step method specified in the Guidelines on the calculation of fines.

2.1.1. Step 1: Identify the processing operations in this case

108. In accordance with the Guidelines on the calculation of fines, it is essential that the supervisory authority first determines whether one or more behaviors of the controlled party are subject to sanctions and whether these give rise to one or more violations attributable to the controlled party, taking into account the circumstances of the case. The said guidelines specify that when it comes to evaluating the same processing operation or related processing operations, the supervisory authority may take into consideration, as part of its assessment of the violations, all legal obligations necessary for the processing operations to be carried out in compliance with the laws, including, for example, transparency obligations (e.g., Article 13 of the GDPR).

109. As noted above, the controlled party is to be considered as the data controller within the meaning of the GDPR for the processing of personal data carried out in response to requests from the data subjects addressed to it (see point 30 of this decision). Furthermore, the Restricted Formation notes that from its analysis of the 47 complaints retained by the head of the investigation in his communication of grievances in response, it appears that the controlled party did not respond to the requests of the data subjects within the required timeframes. It has thus violated Article 12, paragraphs 3 and 4 of the GDPR on 46 occasions (see Part II.1., Chapter B., Section 2.2. of this decision). In this case, it therefore considers that it is a matter of sanctioning a single behavior.

55 Guidelines on the calculation of fines, Chapter 3; point 25 and following.

56 Guidelines on the calculation of fines, point 27.

2.1.2. Step 2: Set the starting amount for the subsequent calculation of the fine

110. In accordance with the Guidelines on the calculation of fines, the supervisory authority must, secondly, set the starting amount for the subsequent calculation of the fine taking into account the circumstances of the case and based on the assessment of three elements:

- the classification of the violations under Article 83, paragraphs 4 to 6 of the GDPR;
- the severity of the violation; and
- the turnover of the company.

2.1.2.1. The classification of violations under Article 83, paragraphs 4 to 6 of the GDPR

111. Regarding the classification of violations, the GDPR provides for two categories, namely violations punishable under Article 83, paragraph 4 of the GDPR and violations punishable under Article 83, paragraphs 5 and 6 of the GDPR. Concerning the first category of violations, the maximum amount of the fine that can be imposed is 10 million euros or 2% of the annual turnover of the company, with the higher amount being retained. Regarding the second category of violations, the maximum amount of the fine that can be imposed is 20 million euros or 4% of the annual turnover of the company, with the higher amount being retained. Through this categorization, the European

legislator has provided a first (abstract) indication of the severity of the violation. Indeed, the more serious the violation, the more likely the fine is to be high.

112. The Restricted Formation notes that insofar as a breach of Article 12, paragraphs 3 and 4 of the GDPR is attributed to the controlled party, the maximum amount of the fine that can be imposed is 20 million euros or 4% of the annual turnover of the company, with the higher amount being retained, in accordance with Article 83, paragraph 5 of the GDPR.

2.1.2.2. The severity of the violation

113. Regarding the determination of the severity of the violation, it is necessary to examine the nature, gravity, and duration of the violation (Article 83, paragraph 2, point a) of the GDPR), as well as its intentional or negligent character (Article 83, paragraph 2, point b) of the GDPR).

57 Guidelines on the calculation of fines, Chapter 4.

58 Guidelines on the calculation of fines, point 48.

59 Guidelines on the calculation of fines, points 49 and 50.

Decision of the National Commission sitting in a restricted formation on the outcome of investigation no. [...] conducted with "Company A"

34/46

GDPR) and the categories of personal data concerned by the breach (Article 83, paragraph 2, point g) of the GDPR)⁶⁰.

114.

Regarding the nature of the breach (Article 83, paragraph 2, point a) of the GDPR), the Restricted Formation recalls, concerning the failure to comply with Article 12, paragraphs 3 and 4 of the GDPR, that transparency is an essential obligation imposed on data controllers. The GDPR grants data subjects rights that they can exercise to ensure they are fully aware of how their personal data will be used once collected, and that they can exercise control over their personal data. Furthermore, the right to transparency has been strengthened by the GDPR, notably through the introduction of deadlines to be respected by a data controller following a request to exercise a right by a data subject, based on Articles 15 to 22 of the GDPR. This underscores the particular importance of this right. Thus, if the controller does not respond to the requests of data subjects within the prescribed deadlines, the effective exercise by data subjects of the rights conferred upon them by the GDPR is not ensured, which constitutes an infringement of those rights.

115.

Regarding the severity of the breach (Article 83, paragraph 2, point a) of the GDPR), the Restricted Formation takes into account the number of affected data subjects and the level of harm they have suffered.

116.

Concerning the number of affected data subjects, after its analysis, the Restricted Formation notes that out of 47 of the complaints retained by the head of the investigation, in his communication of grievances in reply, the failure to comply with Article 12, paragraphs 3 and 4 of the GDPR concerns 46 individuals (see Part II.1., Chapter B., Section 2.2 of this decision).

The controller indicated that between 2018 and 2022, the number [of clients] averaged [...] ⁶¹. Thus, the Restricted Formation considers that the number of affected data subjects is residual compared to the number [of clients].

117.

Regarding the level of harm suffered by the affected data subjects, Recital (75) of the GDPR specifies that it is not only about physical and material damages but also moral harm. Furthermore, the guidelines of the

60 Guidelines on the calculation of fines, point 51. and following.

61 See email from the controller dated June 20, 2024; see also point 2. of this decision.

Decision of the National Commission sitting in a restricted formation on the outcome of investigation no. [...] conducted with "Company A"

35/46

CEPD62 specifies that supervisory authorities must take into account the damages suffered or likely to be suffered, although judicial authorities are competent to identify the different forms of individual damage and grant compensation.

It considers that by failing to respond to the requests of the concerned individuals within the stipulated deadlines, the controlled entity temporarily prevented them from exercising control over their personal data [...], such that the breach identified in Article 12, paragraphs 3 and 4 of the GDPR is likely to have caused harm to the concerned individuals.

118.

Regarding the question of whether the violation was committed intentionally or negligently (Article 83, paragraph 2, point b) of the GDPR), the Restricted Formation recalls that "intention," meaning an offense committed deliberately, encompasses both knowledge and will in relation to the characteristics of an offense, while "non-intentionally" (by negligence) means that there was no intention to commit the violation, although the data controller or processor did not comply with the duty of care imposed on them by the legislation⁶³.

Furthermore, in a ruling dated December 5, 2023, the CJEU (Grand Chamber) held that an administrative fine under Article 83 of the GDPR can be imposed "only if it is established that the data controller, who is both a legal entity and a business, has committed, intentionally or negligently, a violation referred to in paragraphs 4 to 6 of this article"⁶⁴. In this regard, the CJEU clarified "that a data controller can be sanctioned for behavior falling within the scope of the GDPR as long as this data controller could not have been unaware of the unlawful nature of their behavior, whether or not they were aware of violating the provisions of the GDPR [...]"⁶⁵.

119.

As mentioned in point [109.] of this decision, the controlled entity did not respond to the requests of the concerned individuals within the deadlines set out in Article 12, paragraphs 3 and 4 of the GDPR on 46 occasions.

The Restricted Formation considers that the controlled entity could not have been unaware that this non-compliance with the GDPR was objectively constitutive of a violation of the GDPR, especially

62 Guidelines on the application and imposition of fines, page 11 and Guidelines on the calculation of fines, point 53.b)v).

63 Guidelines on the application and imposition of fines, pages 11 to 12.

64 Judgment of December 5, 2023 (Grand Chamber), *Deutsche Wohnen*, C-807/21, ECLI:EU:C:2023:950, point 78; see also the judgment of December 5, 2023 (Grand Chamber), *Nacionalinis visuomenės sveikatos centras*, C-683/21, ECLI:EU:C:2023:949, point 60.

65 Judgments of December 5, 2023 (Grand Chamber), *Deutsche Wohnen*, C-807/21, ECLI:EU:C:2023:950, point 76 and *Nacionalinis visuomenės sveikatos centras*, C-683/21, ECLI:EU:C:2023:949, point 81.

Decision of the National Commission sitting in a restricted formation on the outcome of investigation no. [...] conducted with "Company A"

36/46

more than the National Commission had reminded it of these deadlines several times in the context of handling the complaints in question⁶⁶. Furthermore, it considers that the controlled entity has shown negligence, insofar as the identified breach was due to various human errors by its customer service agents, to the technical error affecting the electronic mailbox [of the DPO], or to identity verifications that were not clearly formulated or sent via inaccessible paths (cf. point [90.] and s. of this decision).

Moreover, the controlled entity, through its behavior, namely its failure to respond to the requests of the data subjects within the required deadlines, has also created a risk of harm affecting the data subjects (cf. point [117.] of this decision).

120. In addition, the Restricted Formation takes into account the statements of the head of the investigation, according to which the fact that the controlled entity did not correct the malfunction of the electronic mailbox [of the DPO] within a short period of time "undoubtedly demonstrates a lack of diligence in managing the exercise of rights requests"⁶⁷. Indeed, the controlled entity was informed of the issue of the failure to respond to certain requests sent by data subjects to the electronic address of the DPO, no later than by the CNPD's letter dated August 6, 2020 (cf. point 76. of this decision). However, the controlled entity did not implement measures to resolve this problem, in order to replace the electronic mailbox [of the DPO], until between December 2020 and April 2021 (cf. point 70. of this decision).

121. However, the Restricted Formation believes that the breach was committed out of negligence while it is of the opinion that the facts and the identified breach do not reflect a deliberate intention to violate the GDPR on the part of the controlled entity.

122. Finally, the Restricted Formation considers that these findings are not undermined by the repeated assertions made by the controlled entity during the Restricted Formation session on June 6, 2024, that its behavior cannot be characterized as negligent since it would have acted as a diligent data controller. In particular, it argues that only an insignificant number of the total requests from data subjects would have been affected by issues related to response times, which would demonstrate that the

66 See, for example, the letters sent by the CNPD to the controlled entity dated August 6, 2020, in the context of the complaints contained in findings no. 6 and 7 of the initial findings (see DOCUMENTS [...]4 and [...]3), the letters sent by the CNPD to the controlled entity dated July 19, 2021, in the context of the complaints contained in findings no. 23 and 24 of the initial findings (see DOCUMENT [...]2 and [...]4), or the letters sent by the CNPD to the controlled entity dated July 29, 2021, in the context of the complaints contained in findings no. 27 and 28 of the initial findings (see DOCUMENTS [...]2 and [...]4).

67 Statement of grievances, point 361.

Decision of the National Commission sitting in a restricted formation on the outcome of investigation no. [...] conducted with "Company A"

37/46

the implemented confidentiality program was functioning⁶⁸. Furthermore, according to the controlled entity, the fact that the head of the investigation did not propose to the Restricted Formation to impose, as a corrective measure, compliance with its confidentiality program would constitute an acknowledgment of the functioning of said program.

On one hand, the Restricted Formation considers that the controlled entity cannot demonstrate that it has complied with the due diligence obligation incumbent upon it under Article 12, paragraphs 3 and 4 of the GDPR, in the context of the 46 complaints for which the Restricted Formation found delays, arguing that the majority of the requests from the data subjects would not have been affected by the issues related to the delays.

On the other hand, it considers that the breach found under Article 12, paragraphs 3 and 4 of the GDPR demonstrates that the precautions taken by the controlled entity to handle requests from data subjects in accordance with the framework set by the GDPR have, at least in part, not functioned. Furthermore, it believes that the head of the investigation did not propose to the Restricted Formation to impose corrective measures aimed at achieving compliance with the provisions of the GDPR because this breach cannot be remedied retroactively. The fact that in this case the head of the investigation did not propose to the Restricted Formation to impose such measures does not mean

that the confidentiality program implemented by the controlled entity was functioning satisfactorily in all cases.

Considering its assessment of the relevant criteria of Article 83, paragraph 2 of the GDPR, the Restricted Formation believes that the degree of severity of the violation should be considered low.

2.1.2.3. The company's turnover 123.

Regarding the company's turnover, the Restricted Formation notes that, insofar as a breach of Article 12, paragraphs 3 and 4 of the GDPR is attributed to the controlled entity, the maximum amount of the fine that can be imposed is 20 million euros or 4% of the annual turnover of the company, with the higher amount being retained, in accordance with Article 83, paragraph 5 of the GDPR. This article states that the total global annual turnover for the previous financial year must be considered.
124.

Furthermore, the Restricted Formation recalls that in accordance with European Union law and the case law of the CJEU, it is in the specific context of calculating administrative fines that the reference made in recital (150) of the GDPR to the notion of "enterprise" as defined in Articles 101 and 102 of the

68 According to the written observations of the controlled entity on the communication of the grievances in reply (point 12.) [...].

Decision of the National Commission sitting in a restricted formation on the outcome of investigation no. [...] conducted with "Company A"

38/46

TFEU. Therefore, the term "enterprise" is defined as the "economic unit," which consists of a unified organization of personal, material, and immaterial elements pursuing a specific economic goal sustainably, even if, from a legal perspective, this economic unit is made up of several natural or legal persons⁶⁹. Thus, it considers that in this case, the economic unit to be taken into account, in light of the violation in question, is the one of which the controlled entity is a part along with Company B. [...]

125. It notes that the consolidated net revenue of Company B for the year 2023 amounted to [...] according to the annual accounts for the year 2023⁷⁰, which the controlled entity transmitted to the Restricted Formation by email on June 20, 2024.

2.1.3. Step 3: Assess aggravating and mitigating circumstances

126. In accordance with the Guidelines on the calculation of fines, the supervisory authority must, thirdly, assess whether any aggravating or mitigating circumstances apply to the circumstances of the case⁷¹. The guidelines specify that the supervisory authority must take each criterion provided for in Article 83, paragraph 2 of the GDPR into consideration only once. Thus, after evaluating, in Step 2, the nature, severity, and duration of the violation (Article 83, paragraph 2, point a) of the GDPR), as well as its intentional or negligent character (Article 83, paragraph 2, point b) of the GDPR), and the categories of personal data concerned (Article 83, paragraph 2, point g) of the GDPR), the supervisory authority must evaluate the other aggravating and mitigating circumstances under Article 83, paragraph 2 of the GDPR (Article 83, paragraph 2, points c), d), e), f), h), i), j), and k) of the GDPR)⁷².

127. As for the measures taken by the controlled entity to mitigate the damage suffered by the data subjects (Article 83, paragraph 2, point c) of the GDPR), the Restricted Formation, without prejudging the adequacy of the responses provided by the controlled entity, notes that out of the 46 complaints it retained, 42 claimants, which is still approximately 91.3% of the data subjects, received a response to their request, and the CNPD is therefore only aware of four data subjects who did not receive a response.

69 Judgment of December 5, 2023, Deutsche Wohnen, C-807/21, ECLI:EU:C:2023:950, paragraphs 56 and 57; see also Guidelines on the application and setting of fines, page 6 and Guidelines on the calculation of fines, point 118 and following.

70 Company B, [Annual report for the fiscal year 2023] [...].

Decision of the National Commission sitting in a restricted formation on the outcome of investigation no. [...] conducted with "Company A"

39/46

response. Thus, the Restricted Formation notes that the controller made efforts to respond to the requests of the concerned individuals. However, most of the responses in question were only provided to the claimants following the intervention of the CNPD, within the framework of the respective complaint procedures. Therefore, the Restricted Formation is of the opinion that these circumstances should be considered neutral.

128. Regarding the degree of responsibility of the data controller or the processor, taking into account the technical and organizational measures implemented under Articles 25 and 32 of the GDPR (Article 83, paragraph 2, point d) of the GDPR), the Restricted Formation notes that despite the controller's confidentiality program (cf. point 61 et seq. of this decision) and in particular the measures implemented by the controller to ensure that requests from concerned individuals are honored within the required timeframes⁷³, various human errors committed by its customer service agents were the cause of a delayed response or a lack of response by the controller to the requests of the concerned individuals (cf. Part II.1., Chapter B., Section 2.2. of this decision). Furthermore, regarding the electronic mailbox [of the DPO], the Restricted Formation has already noted in point 81 of this decision that since during the problematic period certain emails sent to [the DPO's email address] were processed by the controller, it does not consider that there was a total failure of the DPO's electronic mailbox, but that it was affected by a malfunction. Therefore, in light of the efforts made by the controller, the Restricted Formation is of the opinion that these circumstances should be considered neutral.

129. Regarding the degree of cooperation established with the CNPD, in order to remedy the violation and mitigate any potential negative effects (Article 83, paragraph 2, point f) of the GDPR), the Restricted Formation takes into account that the investigation leader noted in the communication of grievances "the satisfactory cooperation of the Controller in this case"⁷⁴. However, it notes that the controller was subject to a general obligation of cooperation under Article 31 of the GDPR. Therefore, it is of the opinion that these circumstances should be considered neutral.

130. Regarding how the CNPD became aware of the violation (Article 83, paragraph 2, point h) of the GDPR), the Restricted Formation notes that the CNPD was informed of the facts constituting the violation in the context of the processing of the complaints in this decision. Nevertheless, it is of the opinion that these circumstances should be considered neutral.

131. Regarding any other aggravating or mitigating circumstances applicable to the circumstances of the case (Article 83, paragraph 2, point k) of the GDPR), the Restricted Formation takes into account the following elements:

- The claims of the investigation leader that "the Controller is a player [...] with [...] significant resources enabling it to address issues of personal data protection" such that "failures in managing requests for the exercise of rights are concerning"⁷⁵. The Restricted Formation is of the opinion that these circumstances should be considered aggravating;
- The claims of the investigation leader that the decrease over the years in the number of complaints related to non-compliance with the response time to requests from concerned individuals constitutes "an indication of an improvement in the management system for requests for the exercise of rights" of the controller⁷⁶. The Restricted Formation is of the opinion that these circumstances should be considered mitigating;
- The ongoing efforts of the controller to improve its confidentiality program to comply with the GDPR⁷⁷. The Restricted Formation particularly notes that according to the controller, the average response time to requests from concerned individuals would have been reduced [...] although during

the same period, the number of requests received per year increased [...]78. It is of the opinion that these circumstances should also be considered mitigating;

– In three of the complaints contained in the initial findings79 for which the Restricted Formation found a breach of Article 12, paragraphs 3 and 4 of the GDPR, the controller argued that the COVID-19 pandemic would constitute an exonerating circumstance, if not a mitigating circumstance regarding the breach in question (cf. point 63 of this decision). However, the Restricted Formation believes that this assertion is not sufficient to excuse the

75 Communication of grievances, point 366.

76 Communication of grievances, point 377.

77 See comments from the controller on the initial findings, point 1 as well as the written observations of the controller on the communication of grievances, point 205 et seq.

78 Observations of the controller on the communication of grievances, point 145; see also [...] which was attached to the comments of the controller on the initial findings.

79 See the complaints contained in findings no. 21, 22, and 31 of the initial findings.

Decision of the National Commission sitting in a restricted formation on the outcome of investigation no. [...] conducted with "Company A"

40/46

Decision of the National Commission sitting in a restricted formation on the outcome of investigation no. [...] conducted with "Company A"

41/46

delays in the three claims at issue. In this case, the controlled entity did not demonstrate how the COVID-19 pandemic could have explained all the unjustified delays, in light of Article 12, paragraphs 3 and 4 of the GDPR, identified by the CNPD. On the contrary, it insisted that it had responded to the vast majority of requests from the data subjects within the required timeframes. In particular, the Restricted Formation considers that the argument that the controlled entity's mailroom was not fully operational during the problematic period is irrelevant in this case, given that, in the context of the claims contained in findings no. 21 and 22, postal mail was received promptly (see points [...] of this decision). Furthermore, as noted by the head of the investigation, regarding the findings for which the controlled entity invoked this circumstance, the requests from the data subjects were submitted between September 2020 and January 2021. At that time, the pandemic had already been ongoing for at least 6 months, so the necessary adaptations should have been made by the controlled entity. Therefore, the Restricted Formation is of the opinion that these circumstances should not be considered as mitigating but simply as neutral.

132. The Restricted Formation notes that the other criteria of Article 83, paragraph 2 of the GDPR are neither relevant nor likely to influence its decision regarding the imposition of an administrative fine and its amount.

133. Therefore, taking into account the assessment of the relevant criteria of Article 83, paragraph 2 of the GDPR, the Restricted Formation considers that the imposition of an administrative fine is justified for the breach of Article 12, paragraphs 3 and 4 of the GDPR. Nevertheless, in light of the preceding developments, it believes that although this is a violation that, due to its severity, falls under the provisions of Article 83, paragraph 5, of the GDPR, the degree of severity should be considered as low.

2.1.4. Step 4: Determine the applicable legal maximum amounts [...]

134. In accordance with the Guidelines on the calculation of fines, the supervisory authority must, fourthly, determine the applicable legal maximum amounts. The guidelines remind that the GDPR does not assign fixed amounts to specific violations but that the GDPR provides for general maximum

amounts. Therefore, it is necessary to ensure that these maximum amounts are not exceeded.

135. The Restricted Formation has already noted that the consolidated net turnover of the company, namely Company B, for the year 2023 amounted to [...] (see point [125.] of this decision).

136. It notes that, insofar as a breach of Article 12, paragraphs 3 and 4 of the GDPR is attributed to the controlled entity, the maximum amount of the fine that can be retained is 4% of the annual turnover of the company in accordance with Article 83, paragraph 5 of the GDPR, namely [...]. [...]

137. In this case, considering the classification of the violation in question under Article 83, paragraph 5 of the GDPR, its low degree of severity, as well as the turnover of the company and the assessment of aggravating or mitigating circumstances in this case, the Restricted Formation considers that the administrative fine to be imposed should amount to 175,000 (one hundred seventy-five thousand) euros.

2.1.5. Step 5: Determine whether the final amount of the calculated fine is effective, proportionate, and deterrent

138. In accordance with the Guidelines on the calculation of fines, the supervisory authority must, fifthly, ensure that the administrative fine imposed for the GDPR violations referred to in Article 83, paragraphs 4 to 6 is, in each case, effective, proportionate, and deterrent, as required by Article 83, paragraph 1 of the GDPR. According to the EDPB, it is the responsibility of the supervisory authority to verify whether the amount of the fine imposed meets these requirements or whether other adjustments to the amount are necessary.

139. The Restricted Formation considers that the amount of the fine appears to be both effective, proportionate, and deterrent, in accordance with the requirements of Article 83, paragraph 1 of the GDPR.

[...]

83 Guidelines on the calculation of fines, points 112. and 113.

84 Guidelines on the calculation of fines, Chapter 7.

85 Guidelines on the calculation of fines, point 132.

Decision of the National Commission sitting in a restricted formation on the outcome of investigation no. [...] conducted with "Company A"

42/46

Decision of the National Commission sitting in a restricted formation on the outcome of investigation no. [...] conducted with "Company A"

43/46

2.1.6. Appropriateness of the administrative fine

140.

The Restricted Formation considers that its decision to impose an administrative fine is not undermined by the claims made by the controlled party during the session of the Restricted Formation on June 6, 2024, asserting that the imposition of a fine would be neither necessary nor proportionate. The controlled party particularly argued that the Advocate General noted in his conclusions in the "Land Hessen" case⁸⁶ that supervisory authorities are expected to respect the principle of proportionality when imposing administrative fines and that the imposition of an administrative fine constitutes a particularly severe corrective measure that should not be resorted to in all cases. In this context, it also emphasized that in this instance, the infringement would have ceased to exist.

141.

In its judgment of September 26, 2024, regarding the case cited by the controlled party, the CJEU ruled that in the event of a finding of a violation of personal data, the supervisory authority is not

required to adopt a corrective measure, particularly an administrative fine, under Article 58(2) of the GDPR when such intervention is not appropriate, necessary, or proportionate to remedy the identified shortcoming and ensure full compliance with this regulation⁸⁷.

Furthermore, the CJEU noted that the GDPR leaves the supervisory authority with a margin of discretion regarding how it should remedy the identified shortcoming since Article 58(2) of the GDPR grants this authority the power to adopt various corrective measures. However, it held that this margin of discretion is limited by the necessity to ensure a consistent and high level of protection of personal data through a rigorous application of the rules⁸⁸.

142.

The Restricted Formation notes that in accordance with Article 58(2)(i) of the GDPR, the CNPD may impose an administrative fine in addition to or instead of the other measures referred to in Article 58(2) of the GDPR.

Moreover, it follows from Recital (148) of the GDPR that “[i]n the case of a minor infringement or if the fine that could be imposed constitutes a disproportionate burden for a natural person, a reprimand may be issued rather than a fine.” However,

86 CJEU, Conclusions of Advocate General Mr. Priit Pikamäe of April 11, 2024, Land Hessen (Obligation of the data protection authority to act), C-768/21, ECLI:EU:C:2024:291).

87 Judgment of September 26, 2024, Land Hessen (Obligation of the data protection authority to act), C-768/21, ECLI:EU:C:2024:785), paragraph 50.

88 Ibid., paragraphs 37 and 38.

Decision of the National Commission sitting in a restricted formation on the outcome of investigation no. [...] conducted with "Company A"

44/46

due consideration must be given to the criteria listed in this recital, which are almost identical to those in Article 83(2) of the GDPR.

In this regard, the Guidelines on the application and setting of fines specify that this recital does not obligate the supervisory authority to automatically replace the fine with a reprimand in the case of a minor infringement, but it allows the authority to do so after a concrete assessment of all the circumstances of the case⁸⁹.

Considering the assessment of the relevant criteria of Article 83(2) of the GDPR, and notwithstanding the low degree of severity of the infringement, it falls under the application of Article 83(5). The Restricted Formation therefore believes that an administrative fine is warranted to deter other controllers from committing a similar infringement. [...]

Furthermore, the imposition of an administrative fine by the Restricted Formation is necessary to ensure consistency in the sanctioning policy applied by the CNPD, in relation to other controllers and processors.

In light of the above, the Restricted Formation considers that the imposition of a fine is an appropriate sanction according to the specific circumstances of the case.

2.2. Regarding the adoption of corrective measures

143.

In the statement of objections, the head of the investigation also proposed to the Restricted Formation to adopt the following corrective measure: “a reprimand, within the meaning of Article 58(2)(b) of the GDPR”⁹⁰. According to him, “it is necessary to remind the Controlled party of the need to inform each data subject, without undue delay and at the latest within one month of receiving a request to exercise rights, as enshrined in Articles 15 to 22 of the GDPR, regarding the follow-up to the request to exercise rights or, if the Controlled party does not intend to comply with the request, regarding the reasons for its inaction”⁹¹.

144.

The controlled party, in its written observations and during the session of the Restricted Formation on June 6, 2021, argued that, based on the facts of the case, it should not be sanctioned (see paragraph

[105.] of this decision).

89 Guidelines on the application and setting of fines, page 9.

90 Statement of objections, paragraph 359.

91 Statement of objections, paragraph 360.

Decision of the National Commission sitting in a restricted formation on the outcome of investigation no. [...] conducted with "Company A"

45/46

145.

However, it emerges from the analysis of the Restricted Formation of the 47 complaints retained by the head of the investigation in his communication of grievances in reply, that the controlled entity did not respond to the requests of the concerned individuals within the required deadlines, thereby violating Article 12, paragraphs 3 and 4 of the GDPR, and this on 46 occasions (see point [109.] of this decision).

Thus, in light of the breach retained against the controlled entity, it considers that the imposition of the corrective measure proposed by the head of the investigation in this regard and reiterated in point [143.] of this decision, is appropriate and necessary to ensure compliance with the deadlines set by Article 12, paragraphs 3 and 4 of the GDPR by the controlled entity in the future.

It therefore aligns with the position of the head of the investigation, according to which it is necessary to reprimand the controlled entity, in accordance with Article 58, paragraph 2, point b) of the GDPR, for having violated Article 12, paragraphs 3 and 4 of the GDPR.

In light of the preceding developments, the National Commission sitting in a restricted formation, after deliberation, decides:

-

to retain a breach of Article 12, paragraphs 3 and 4 of the GDPR;

-

to issue a reprimand against Company A for failing to comply with Article 12, paragraphs 3 and 4 of the GDPR;

-

to impose an administrative fine of 175,000 (one hundred seventy-five thousand) euros against Company A for failing to comply with Article 12, paragraphs 3 and 4 of the GDPR.

Belvaux, January 6, 2025.

The National Commission for Data Protection sitting in a restricted formation

Tine A. Larsen Thierry Lallemand

Marc Lemmer

President

Commissioner

Commissioner

Decision of the National Commission sitting in a restricted formation on the outcome of investigation no. [...] conducted with "Company A"

46/46

Indication of appeal avenues

This administrative decision may be subject to an appeal for reform within three months following its notification. This appeal must be brought before the administrative court and must necessarily be introduced through a lawyer at the Court of one of the Bar Associations.